



EMHIP — Ethnicity & Mental Health Improvement Project

EMHIP — UK GDPR compliance register

Contents

1. Principles — Article 5
2. Data-subject rights — Chapter III
3. Security of processing — Article 32
4. Records of processing — Article 30 (data inventory)
5. Processors and international transfers — Articles 28 and 44–49
6. Remaining actions for the organisation
7. What the 2026-09-09 release added

EMHIP processes **special-category personal data** (mental-health records, ethnicity, NHS numbers) about hub guests, plus the activity of the staff who use it. This register maps the requirements of the UK GDPR and the Data Protection Act 2018 to the controls in the codebase, and lists what remains for the organisation (the controller) to do. Last reviewed with the 2026-09-09 release.

Status key: **Implemented** = enforced by the code · **Partly** = technical part done, organisational part outstanding · **Organisational** = policy/contract/process, outside the code.

1. Principles — Article 5

Requirement	Control in EMHIP	Where	Status
Lawfulness, fairness, transparency (5(1)(a), Art. 6, Art. 9(2)(h))	Consent recorded at registration (<code>Guest.ConsentGiven/At</code> , required by the validator) and re-confirmed at the initial conversation. Lawful bases must still be written into the privacy notice / ROPA.	<code>Guest.cs</code> , <code>RegisterGuestCommand</code> , <code>InitialConversationRecord</code>	Partly
Purpose limitation (5(1)(b))	List, search, dashboard, report, access-log and export queries are scoped to the caller's hub; one authorisation policy per permission; separate claims for exporting, anonymising and viewing the access log. The guest record tabs look a guest up by id without a hub check (reviewed 30 September 2026): harmless while there is one hub, but add the check before a second hub is created.	<code>Permissions.cs</code> , <code>Program.cs</code> , every controller, <code>GetGuestWorkspaceQueries.cs</code>	Partly
Data minimisation (5(1)(c))	Anonymisation keeps only the pseudonymous record; the audit log records <i>which</i> fields changed, never values; exports limited to <code>guests.export</code> holders.	<code>Guest.Anonymise()</code> , <code>AuditSaveChangesInterceptor</code> , <code>GuestsController</code>	Implemented
Accuracy (5(1)(d))	Clinical records are append-only and versioned (risk assessments, pathway changes, document versions); demographics and contact details are editable in place with an audit trail.	<code>RiskAssessment</code> , <code>PathwayChange</code> , <code>DocumentVersion</code>	Implemented

Requirement	Control in EMHIP	Where	Status
Storage limitation (5(1)(e))	Documents carry a retention date (default 7 years; purge blocked before it). <code>compliance.recordRetentionYears</code> (default 20, NHS Records Management Code for adult mental health) flags records for retention review on the Data Quality report; anonymisation closes them.	<code>SettingsCatalog</code> , <code>ReportReadService</code> , <code>Document.IsRetained</code>	Implemented (review is deliberately manual)
Integrity & confidentiality (5(1)(f), Art. 32)	See section 3.		Partly
Accountability (5(2))	Every read, write, download, export and anonymisation is written to <code>AuditEvents</code> ; per-guest Access Log tab for Hub Managers/Admins; export history.	<code>AuditReadLoggingMiddleware</code> , <code>IAuditTrail</code> , <code>GuestAccessLogTabComponent</code>	Implemented

2. Data-subject rights – Chapter III

Right	Control in EMHIP	Status
Access (Art. 15)	<code>GET /guests/{id}/export</code> builds the complete record (all tabs, documents metadata, urgent episodes, access log) as JSON; "Export Record" in the workspace; logged as a disclosure and in export history.	Implemented
Rectification (Art. 16)	Demographics / contact details editable; clinical corrections are new versions, never overwrites.	Implemented
Erasure (Art. 17)	"Anonymise record": strips name, DOB (year kept), contact details, address, NHS number, GP and emergency-contact details; retires documents to the recycle bin; hides the record; reason kept on the audit log; blocked while an urgent episode is open. Health records that must be retained are anonymised rather than destroyed.	Implemented
Restriction (Art. 18)	No dedicated "restrict processing" flag, and status cannot be set by hand — record the request as a pinned note on the guest so every user sees it, and stop further processing by agreement. A guest with no activity becomes Inactive automatically after the inactivity threshold (90 days by default).	Organisational
Portability (Art. 20)	The Art. 15 export is machine-readable JSON.	Implemented
Objection (Art. 21) / Automated decisions (Art. 22)	No automated decision-making: the escalation worker only surfaces flags a clinician raised; humans decide. Objections handled by process.	Organisational

3. Security of processing — Article 32

Control	Detail	Where
Transport	TLS terminated at the host proxy; HSTS from the API (outside Docker) and from nginx.	<code>Program.cs</code> , <code>client/nginx.conf</code>
Browser hardening	<code>Content-Security-Policy</code> , <code>X-Content-Type-Options: nosniff</code> , <code>X-Frame-Options: DENY</code> , <code>Referrer-Policy: no-referrer</code> , <code>Permissions-Policy</code> , <code>Cache-Control: no-store</code> on every API response.	<code>SecurityHeadersMiddleware</code> , <code>client/nginx.conf</code>
Authentication	ASP.NET Core Identity, 10-char minimum password, lockout after 5 failures for 15 minutes, 10 requests/minute per IP on login / forgot / reset. Same response for unknown, inactive, locked and wrong-password accounts.	<code>Program.cs</code> , <code>AuthController</code>
Session	JWT valid 8 h; automatic sign-out after 30 minutes idle (setting <code>security.sessionIdleMinutes</code> , warning 60 s before); token only ever sent to EMHIP's own API.	<code>IdleTimeoutService</code> , <code>auth.interceptor.ts</code>
Authorisation	Per-permission policies; hub scoping; author-only edits on draft notes and attachments.	<code>Permissions.cs</code> , command handlers
Integrity	SHA-256 recorded for every document version and returned on download; storage keys sanitised; path-escape guard on local storage.	<code>DocumentCommands</code> , <code>LocalDocumentStorage</code>
Service-to-service	Worker → API secret compared in constant time.	<code>InternalNotificationsController</code>
Encryption at rest	Not in the application. Enable SQL Server TDE (or Always Encrypted for <code>NhsNumber</code> , contact fields) and encrypted backups at the platform level.	Organisational / infrastructure
MFA	Not implemented; NHS DSPT strongly recommends MFA for clinical systems.	Organisational / roadmap

4. Records of processing — Article 30 (data inventory)

Data set	Content	Category	Retention
Guest	Name, DOB, gender, phone, email, address, postcode, consent, status, pathway	Personal	<code>compliance.recordRetentionYears</code> (20 y) then anonymise
Guest demographics	Ethnicity, nationality, language, housing, employment, marital status, country of origin, emergency contact, GP, NHS number	Special category (ethnicity, health context)	As guest
Clinical record	Risk assessments, casework (SBAR) notes, CPN assessments, DIALOG scores, care plans, urgent episodes, MDT queue	Special category (health)	As guest (pseudonymised on anonymisation)

Data set	Content	Category	Retention
Documents	Uploaded files and versions, incl. casework-note attachments	Personal / special category	<code>documents.retentionYears</code> (7 y default), purge blocked before
Audit events	Staff id, action, entity, field names changed, timestamps	Personal (staff)	Kept for the life of the record it protects
Staff accounts	Email, display name, roles, password hash, logout state	Personal (staff)	Deactivated, never deleted

5. Processors and international transfers — Articles 28 and 44–49

- **Hosting** (`emhip.brainshub.co.uk`, host `/opt/emhip`): needs a written data-processing agreement and confirmation of UK/EU data residency.
- **Email** (SMTP / Amazon SES / Mailgun — Mailgun offers an EU endpoint in Settings): processor agreement per provider actually enabled.
- **Object storage** (S3 / S3-compatible / Azure / GCS, if enabled): processor agreement and region choice.
- **Google Fonts**: the SPA loads Plus Jakarta Sans, Wix Madefor Display, Inter and Manrope from `fonts.googleapis.com`, which sends each staff member's IP address to Google on page load. Either self-host the four families (drop the `@import` in `client/src/styles.scss`, ship the `.woff2` files, tighten the CSP) or name Google in the staff privacy notice.

6. Remaining actions for the organisation

1. **DPIA** (Art. 35) — required: health data of vulnerable people at scale. This register supplies the technical inputs.
2. **Privacy notices** for guests (given at registration, referenced by the consent checkbox) and for staff (audit logging of their activity, Google Fonts).
3. **ROPA** (Art. 30) using section 4; name the Art. 6 and Art. 9 bases per data set.
4. **DPO** appointment (Art. 37 — likely required) and a **breach procedure** meeting the 72-hour notification duty (Art. 33); the audit log and export history support the investigation.
5. **Processor agreements** (section 5) and a decision on self-hosting fonts.
6. **Platform encryption**: TDE / encrypted volumes, encrypted and tested backups, replace `TrustServerCertificate=True` with a trusted certificate in production, rotate the placeholder `JWT_KEY` and `INTERNAL_SHARED_SECRET`.
7. **Access governance**: quarterly review of role permissions (the role editor shows every claim), joiner/leaver process (deactivate accounts), MFA on the roadmap.
8. **Retention operation**: review the "due for retention review" count on the Data Quality report at least annually and anonymise closed records.
9. **Staff training** on the SBAR/consent workflow and on handling subject-access and erasure requests.

7. What the 2026-09-09 release added

Area	Change
Access logging	Reads under <code>/urgent-cases/{guestId}</code> and <code>/urgent-cases/episodes/{id}</code> , document downloads and exports are now logged; updates record the changed field names.

Area	Change
Rights	Subject-access export endpoint and UI (<code>guests.export</code>); anonymisation endpoint and UI with typed confirmation (<code>guests.erase</code>); per-guest Access Log tab (<code>guests.audit.view</code>). Hub Managers get the first two claims; anonymisation is Admin-only until granted.
Security	Security-headers middleware, HSTS, CSP in nginx, Identity logout, per-IP rate limiting on auth endpoints, constant-time internal secret check, idle sign-out with warning, token restricted to the API origin, <code><title></code> fixed.
Retention	<code>compliance.recordRetentionYears</code> setting and the "due for retention review" issue on the Data Quality report.